OWASP COMPLIANCE

AUDIT REPORT

GenAI Top 10 + OWASP Top 10 Security Assessment

TARGET APPLICATION

http://localhost:8081 (Vulnerable Demo App)

RISK SCORE	FINDINGS	OWASP T10	GENAI T10
8.7/10	5	7/10	6/10

Generated: 2026-10-23 18:55 UTC

CONFIDENTIAL - For authorized personnel only

1. Executive Summary

This OWASP compliance audit was conducted against http://localhost:8081 (Vulnerable Demo App). The assessment identified 5 security finding(s) (2 Critical, 3 High, 0 Medium, 0 Low, 0 Informational). The overall risk score is 8.7/10. OWASP Top 10 compliance: 3 categories failed. OWASP GenAI Top 10 compliance: 4 categories failed.

2. OWASP Top 10 (2021) Compliance

ID	CATEGORY	STATUS	FINDINGS	RISK LEVEL
A01:2021	Broken Access Control	FAIL	2	HIGH
A02:2021	Cryptographic Failures	PASS	0	LOW
A03:2021	Injection	FAIL	4	HIGH
A04:2021	Insecure Design	PASS	0	LOW
A05:2021	Security Misconfiguration	FAIL	1	HIGH
A06:2021	Vulnerable and Outdated Components	PASS	0	LOW
A07:2021	Identification and Authentication F	PASS	0	LOW
A08:2021	Software and Data Integrity Failure	PASS	0	LOW
A09:2021	Security Logging and Monitoring Fai	PASS	0	LOW
A10:2021	Server-Side Request Forgery (SSRF)	PASS	0	LOW

3. OWASP GenAI Top 10 (2025) Compliance

ID	CATEGORY	STATUS	FINDINGS	INHERENT	MITIGATIONS
LLM01	Prompt Injection	FAIL	2	CRITICAL	4 controls
LLM02	Insecure Output Handling	FAIL	2	HIGH	3 controls
LLM03	Training Data Poisoning	FAIL	1	HIGH	3 controls
LLM04	Model Denial of Service	PASS	0	MEDIUM	4 controls
LLM05	Supply Chain Vulnerabilities	PASS	0	MEDIUM	3 controls
LLM06	Sensitive Information Disclosu	FAIL	1	HIGH	3 controls
LLM07	Insecure Plugin Design	PASS	0	HIGH	3 controls
LLM08	Excessive Agency	PASS	0	MEDIUM	3 controls
LLM09	Overreliance	PASS	0	MEDIUM	3 controls
LLM10	Model Theft	PASS	0	MEDIUM	3 controls

OWASP

4. Findings by OWASP Category

A01:2021 - Broken Access Control

Status: FAIL | 2 finding(s)

- **[Critical] SQL Injection**
  http://localhost:8081/sqli?id=1
- **[High] Broken Access Control (BOLA/IDOR)**
  http://localhost:8081/api/user/100

A03:2021 - Injection

Status: FAIL | 4 finding(s)

- **[Critical] SQL Injection**
  http://localhost:8081/sqli?id=1
- **[Critical] Remote Code Execution (RCE)**
  http://localhost:8081/rce?cmd=echo 'sc_rce_test'
- **[High] Local File Inclusion (LFI)**
  http://localhost:8081/lfi?file=../../../../etc/passwd
- **[High] Prompt Injection / Insecure Output**
  http://localhost:8081/api/copilot

A05:2021 - Security Misconfiguration

Status: FAIL | 1 finding(s)

- **[High] Local File Inclusion (LFI)**
  http://localhost:8081/lfi?file=../../../../etc/passwd

OWASP AUDIT

5. GenAI Threat Analysis & Mitigations

LLM01: Prompt Injection

[FAIL]

Manipulating LLMs through crafted inputs to cause unintended actions, bypassing safety measures or generating harmful content.

Recommended Controls:

* Input sanitization and validation before LLM processing
* Privilege separation between LLM and system actions
* Human-in-the-loop for sensitive operations

LLM02: Insecure Output Handling

[FAIL]

Insufficient validation of LLM outputs leading to downstream security issues including XSS, CSRF, SSRF, or code execution.

Recommended Controls:

* Treat LLM output as untrusted user input
* Apply output encoding and sanitization
* Validate LLM responses before rendering

LLM03: Training Data Poisoning

[FAIL]

Manipulation of training data to introduce vulnerabilities, backdoors, or biases into the model.

Recommended Controls:

* Validate and curate training data sources
* Implement data integrity verification
* Regular model auditing and testing

LLM04: Model Denial of Service

[PASS

Attackers cause resource-heavy operations on LLMs, leading to service degradation or high costs.

Recommended Controls:

* Rate limiting on LLM API endpoints
* Input length restrictions
* Resource monitoring and auto-scaling limits

LLM05: Supply Chain Vulnerabilities

[PASS

Dependency on vulnerable third-party components, models, or data sources.

Recommended Controls:

* Vet third-party model providers
* Use model signing and verification
* Regular dependency auditing

LLM06: Sensitive Information Disclosure

[FAIL]

LLMs may inadvertently reveal sensitive information through their responses.

Recommended Controls:

* Data sanitization in training and fine-tuning
* PII detection and redaction in outputs
* Access controls on sensitive data

LLM07: Insecure Plugin Design

[PASS

LLM plugins may have insecure input handling, insufficient access controls.

Recommended Controls:

* Parameterized plugin inputs
* Strict access control on plugin actions
* Input validation and sanitization

LLM08: Excessive Agency

[PASS

LLM-based systems may take actions that lead to unintended consequences due to excessive permissions.

Recommended Controls:

* Principle of least privilege for LLM actions
* Human approval for high-impact operations
* Action logging and audit trails

LLM09: Overreliance

[PASS

Blindly trusting LLM outputs without verification can lead to security vulnerabilities.

Recommended Controls:

* Human review of LLM-generated security decisions
* Cross-validation with multiple sources
* Confidence scoring and uncertainty flags

LLM10: Model Theft

[PASS

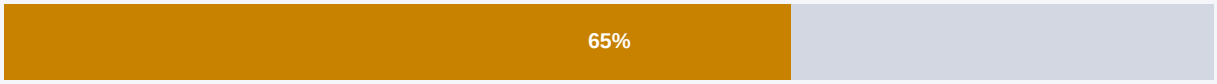
Unauthorized access to or extraction of proprietary LLM models.

Recommended Controls:

* Network segmentation for model endpoints
* API authentication and rate limiting
* Model watermarking

6. Compliance Scorecard

Overall Compliance Score



Framework Breakdown

OWASP Top 10	PASS: 7	PARTIAL: 0	FAIL: 3	70%
OWASP GenAI Top 10	PASS: 6	PARTIAL: 0	FAIL: 4	60%

7. Remediation Roadmap

Phase 1 - Immediate (0-7 days)

Critical and High severity findings | 5 item(s)

> SQL Injection: Use parameterized queries with prepared statements.
> Remote Code Execution (RCE): Avoid invoking shell processes; sanitize and whitelist argum
> Broken Access Control (BOLA/IDOR): Enforce object-level access authorization checks before serv
> Local File Inclusion (LFI): Validate filenames against a strict whitelist; use basename
> Prompt Injection / Insecure Output: Use dual-LLM verification, strict input guardrails, and role

Phase 2 - Short-term (7-30 days)

Medium severity findings and failed OWASP categories | 0 item(s)

Phase 3 - Long-term (30-90 days)

Low severity, informational items, and hardening | 0 item(s)

This report was generated by VerseScan's OWASP GenAI Audit Engine. Findings are mapped automatically using CWE and keyword analysis. For AI-enhanced analysis, connect the LLM Gateway service.